

GTIA6 – GESTÃO E GOVERNANÇA DE TI

Governança Corporativa e Regulamentações de Compliance

Como as exigências regulatórias e o controle corporativo transformam a gestão, a infraestrutura e os processos de TI

Agenda da Sessão

Visão Geral

1 Governança Corporativa e Compliance

2 Governança Corporativa × Governança de TI

3 Controles Internos e Gestão de Riscos (COSO)

4 SOX (Sarbanes-Oxley) e seus Impactos na TI

5 Regulação Bancária: Acordo de Basileia

6 Do Requisito Regulatório ao Controle de TI

Objetivo Central: Compreender a cadeia lógica de como obrigações legais do negócio se traduzem em controles, sistemas e processos tecnológicos.

Por que Compliance é Assunto da TI?

Fundamentação

-  **Exigência Corporativa:** As organizações precisam atender rigorosamente a leis, normas do setor, regulamentações governamentais e políticas internas.
-  **Dependência Tecnológica:** Como quase a totalidade das operações, dados financeiros e informações estratégicas reside em ambiente digital, compliance se torna dependente da TI.
-  **Transformação Operacional:** Os requisitos regulatórios do negócio são obrigatoriamente convertidos em controles de sistemas e infraestrutura.



Conceito de Governança Corporativa

IBGC 2023

“Governança corporativa é um **sistema formado por princípios, regras, estruturas e processos** pelo qual as organizações são dirigidas e monitoradas, com vistas à geração de valor sustentável para a organização, para seus sócios e para a sociedade em geral.”

— Código das Melhores Práticas de Governança Corporativa (IBGC, 6ª edição, 2023)

Governança Corporativa

-  **Decide** o direcionamento estratégico da organização.
-  **Direciona** as diretrizes e prioridades corporativas.
-  **Supervisiona** a gestão e os órgãos executivos.
-  **Controla** riscos globais da empresa.

Governança de TI

Garante que a tecnologia, os recursos e os investimentos de TI estejam estritamente **alinhados a esse direcionamento corporativo**, assegurando conformidade e entrega de valor.

Princípios de Governança Corporativa

IBGC 2023

Os 5 princípios fundamentais atualizados pelo Código de Melhores Práticas do IBGC (2023):



Integridade

Conduta ética, alinhamento de valores e combate a fraudes.



Transparência

Divulgação clara e espontânea de informações relevantes.



Equidade

Tratamento justo e isonômico a todos os sócios e partes.



Responsabilização

Prestação de contas clara por atos e omissões (Accountability).



Sustentabilidade

Zelo pela longevidade, aspectos sociais e ambientais.

Conexão com a TI: Esses princípios não foram criados especificamente para a TI. São diretrizes da empresa inteira que definem como a TI deve ser orientada, auditada e controlada.

COSO: Controles Internos e Gestão de Riscos

Framework

Controle Interno

Garante a eficácia nos 3 pilares corporativos:

- ✓ **Operações:** Eficiência operacional e salvaguarda de ativos.
- ✓ **Relatórios:** Confiabilidade das demonstrações financeiras.
- ✓ **Conformidade:** Aderência total às leis e regulamentos.

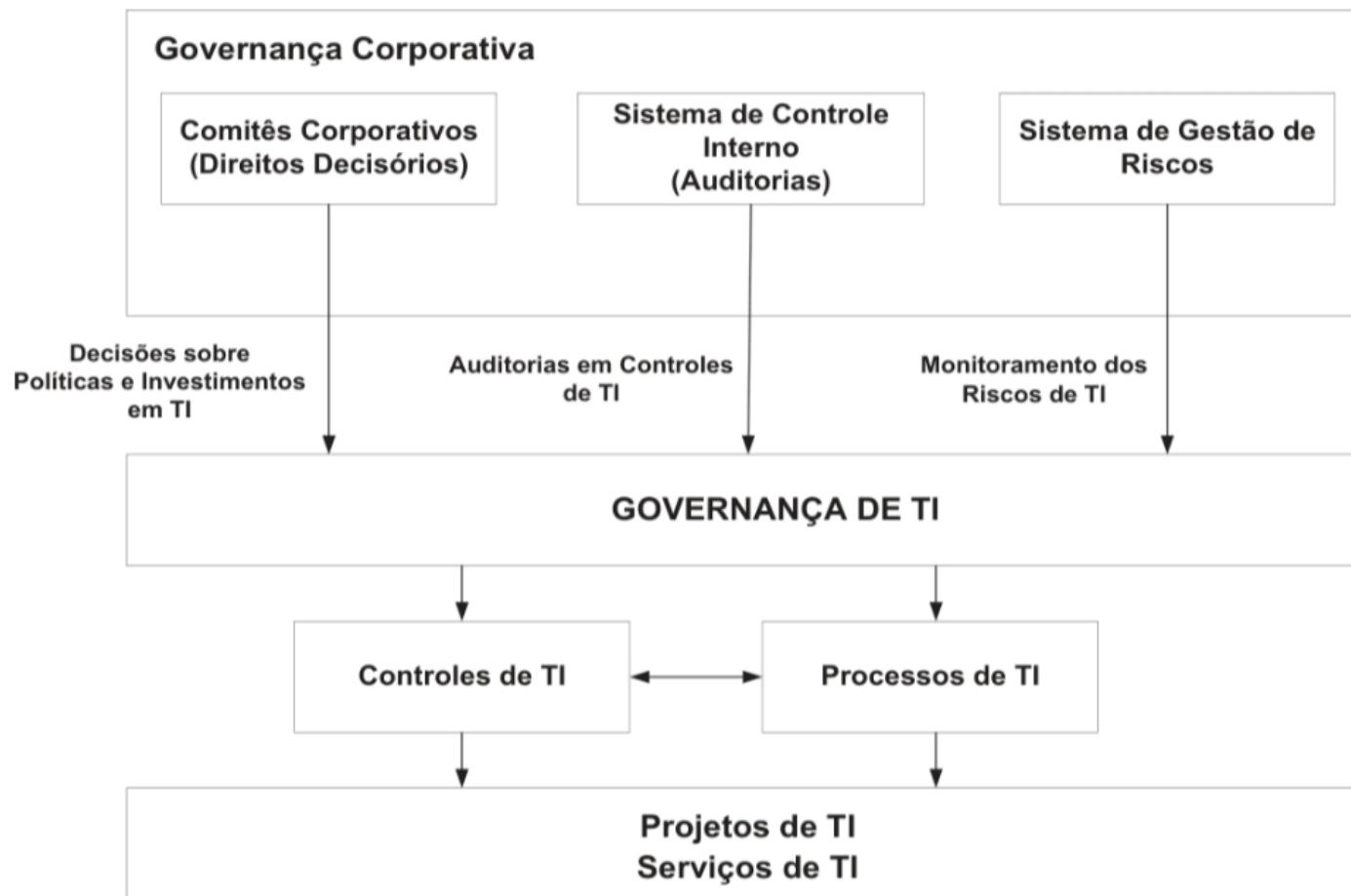
Gestão de Riscos (ERM)

Processo contínuo em 4 etapas principais:

-  **Identificar:** Mapear ameaças potenciais.
-  **Avaliar:** Mensurar impacto e probabilidade.
-  **Responder:** Definir ações de mitigação.
-  **Monitorar:** Acompanhar a efetividade dos controles.

 **Exemplo Prático:** A empresa identifica o risco de vazamento de dados de relatórios financeiros → Determina como resposta o controle de acesso estrito → A TI é acionada para implementar MFA, permissões baseadas em papéis e auditoria de logs.

Integração: Gov. Corporativa × Gov. de TI



🔗 **Conexão com a Aula 01:** Governança de TI não é apenas instalar frameworks (COBIT/ITIL), mas sim atender ao direcionamento e aos controles recebidos da governança corporativa.

Sarbanes-Oxley Act — SOX (2002)

Contexto

Contexto Histórico

-  Grandes fraudes contábeis em empresas norte-americanas de capital aberto (Enron, WorldCom, Tyco).
-  Quebra vertiginosa de confiança dos investidores no mercado de capitais.

Objetivos da Lei

-  Aumentar a confiabilidade das demonstrações financeiras.
-  Fortalecer os controles internos corporativos.
-  Responsabilizar criminalmente e civilmente a alta administração (CEO e CFO).

 **Ideia Central para a TI:** Se os relatórios financeiros dependem de sistemas digitais, a confiabilidade desses relatórios depende diretamente da **efetividade dos controles da TI**.

O que a SOX Exige da Organização?

Requisitos

-  **Responsabilidade da Alta Gestão:** CEO e CFO assumem responsabilidade pessoal direta pela integridade dos controles.
-  **Controles sobre Relatórios Financeiros:** Obrigação de projetar, manter e documentar controles eficazes.
Avaliação de Efetividade: Testes periódicos obrigatórios sobre o funcionamento dos controles internos.
-  **Comunicação de Deficiências:** Divulgação imediata de falhas ou fraudes aos auditores.
-  **Auditoria Externa Independente:** Validação por terceiros da avaliação feita pela diretoria.

⚠ Distinção Fundamental

A SOX não é uma lei de TI. Ela é uma lei financeira e contábil.

Porém, como os dados financeiros são processados em sistemas, os controles de TI passam a fazer parte obrigatória do escopo de compliance e auditoria.

Da SOX ao Controle de TI

Exemplos práticos de como riscos financeiros SOX se convertem em controles de TI:

Risco do Negócio / Financeiro	Controle de TI Correspondente
Usuário altera informação financeira indevidamente	Controle de Acesso (IAM / RBAC)
Programador altera código diretamente em ambiente de produção	Gestão de Mudanças e Segregação de Ambientes
Dados financeiros críticos são perdidos por falha de hardware	Rotinas de Backup e Testes de Restauração
Alterações fraudulentas em lançamentos não podem ser rastreadas	Logs de Auditoria e Imutabilidade de Trilhas
Uma única pessoa lança e aprova pagamentos no sistema	Segregação de Funções (SoD) na Aplicação
Sistema ERP fica indisponível no fechamento do balanço	Gestão de Continuidade e Alta Disponibilidade

SOX: Quais Áreas da TI são Afetadas?

Escopo de TI



Aplicações

- Requisitos de software
- Desenvolvimento seguro
- Validação e testes



Segurança

- Controle de acessos
- Gestão de privilégios
- Proteção de dados



Operações

- Disponibilidade
- Gestão de incidentes
- Suporte e infraestrutura



Mudança

- Gestão de configuração
- Implantações (Deploy)
- Rastreabilidade total



Continuidade

- Políticas de backup
- Plano de recuperação (DRP)
- Planos de contingência

» Toda modificação de código ou infraestrutura que toque relatórios financeiros precisa ser formalmente aprovada, testada e auditável.

O que Compliance Muda na TI?

Impactos

Planejamento

Requisitos regulatórios entram obrigatoriamente no Plano Diretor de TI.

Sistemas

Novos controles, validações e funcionalidades integradas aos softwares.

Processos

Ajustes em gestão de mudanças, incidentes, acessos e operações.

Estrutura

Redefinição de responsabilidades e segregação formal de funções.

Medição

Novos indicadores de desempenho (KPIs), trilhas de auditoria e monitoramento.

Riscos

Acompanhamento contínuo e mitigação proativa de vulnerabilidades.

 **Conclusão do Bloco:** Compliance não é apenas gerar documentação e papéis. Ele altera profundamente sistemas, arquitetura, processos, estrutura operacional e investimentos de TI.

Regulação Bancária: De Basileia II a III

Setor Financeiro

Basileia II (Contexto Histórico)

Acordo estabelecido pelo BIS (Bank for International Settlements). Exige capital mínimo compatível com:

- Risco de Crédito
- Risco de Mercado
- **Risco Operacional** (falhas humanas, de processos e sistemas de TI)

Evolução: Basileia III

Ampliou a exigência de liquidez e capital. O framework atual trata rigorosamente o **risco operacional digital**, incluindo indisponibilidades e falhas tecnológicas.



Regulação Bancária: Requisitos para a TI

Impactos

☰ Exigências Diretas do Setor Bancário

-  **Qualidade e Integridade de Dados:** Granularidade de dados de clientes e operações de crédito.
-  **Segurança da Informação:** Proteção estrita contra acessos não autorizados.
-  **Disponibilidade e Desempenho:** Capacidade de infraestrutura para altos volumes transacionais.
-  **Continuidade e DRP:** Planos de desastre e recuperação de serviços.
-  **Confiabilidade de Relatórios:** Exatidão das informações enviadas ao Banco Central.

🛡️ Cenário Atual: Resiliência Operacional

A discussão regulatória moderna do setor financeiro evoluiu do simples risco operacional para o conceito amplo de **Resiliência Operacional Digital**.

Foco total em: cibersegurança, gestão de dependência de terceiros (nuvem), gestão de incidentes críticos e continuidade de serviços essenciais.

No Brasil: Evolução da Regulamentação

Resolução CMN 3.380/2006

Marco inicial que determinou que as instituições financeiras no Brasil implementassem estrutura própria de gerenciamento de risco operacional.

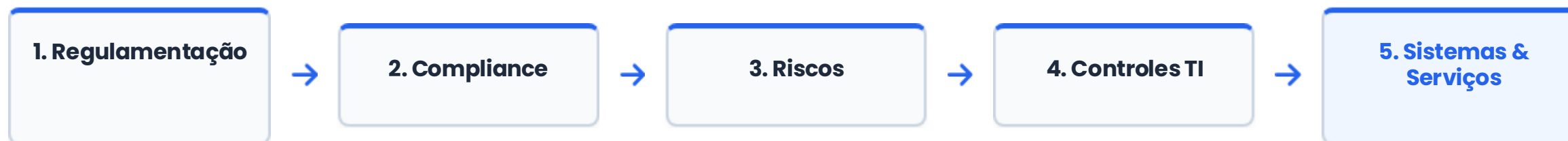
Resolução CMN 4.557/2017

Norma Vigente (substituiu a 3.380): Unificou a estrutura contínua de gerenciamento integrado de riscos (GIR) e de capital, exigindo acompanhamento tecnológico constante.

 **Lição Didática Importante:** Normas e resoluções são revogadas e atualizadas frequentemente. A Governança de TI deve acompanhar continuamente a evolução regulatória do setor para manter o compliance ativo.

Conclusão: Da Regulamentação à TI

Fechamento



"A Governança de TI garante que decisões, processos, controles e recursos tecnológicos estejam alinhados não apenas à estratégia de negócios, mas também aos riscos corporativos e às obrigações legais da organização."

 Perguntas & Discussão